

Directory Auditor — план реализации

От идеи до публичного выпуска 0.1: восемь этапов, девять обязательных шагов, восемь контрольных точек.

План v1
октябрь 2026
для обсуждения с командой

9	обязательных шагов — без них выпуск невозможен или бесполезен	≈ 290 ч до закрытой альфы; ещё ≈ 180 ч до выпуска 0.1	4–7 мес. до альфы при 20 или 10 часах в неделю	≈ \$500–900 сертификат подписи кода и домен; остальное — бесплатные уровни CI
---	---	--	---	--

#	ЭТАП	НЕД.*	ЧТО СДЕЛАТЬ	КОНТРОЛЬНАЯ ТОЧКА
0	Право и решения обязательно	0–2	Письменное согласие работодателя о границе интеллектуальной собственности. Проверка названия (товарные знаки, GitHub, winget, домены). Выбор языка движка (Go или .NET Native AOT), решения по управлению проектом и реестру российского ПО. Заказ сертификата подписи с немедленной репутацией (EV или Trusted Signing) в первый же день — самый долгий срок.	K0: письмо подписано, имя чисто, сертификат заказан. До K0 — ни одного публичного коммита.
1	Каталог проверок v1 обязательно	2–4	≈ 50 проверок по пяти областям (ядро каталога, DNS, групповые политики, PKI, Kerberos) из первичных источников: ATT&CK, Microsoft, ANSSI, SpecterOps, БДУ ФСТЭК. Чистая комната: PingCastle и Purple Knight — только как список пробелов, без кода и текстов.	K1: каталог в репозитории раньше любого кода проверок.
2	Репозиторий и конвейер обязательно	3–6	Организация на GitHub и зеркало в РФ; Apache 2.0, CONTRIBUTING с правилом чистой комнаты, DCO, SECURITY.md. CI: воспроизводимая сборка под три ОС, подпись, SBOM, provenance, тест «только чтение» по таблице символов, лаборатория Samba AD DC в контейнере.	K2: пустой подписанный бинарник собирается и проходит проверки на трёх ОС.
3	Движок и провайдер AD обязательно	5–10	LDAP и Kerberos (подпись и шифрование, channel binding, LDAPS с закреплением отпечатка); архитектура снимков (сбор → снимок → анализ → отчёт); 25 проверок уровня 0; отчёт HTML/JSON/CSV со счётом 0–100; doctor и обучающие сообщения об ошибках; консольный режим.	K3: быстрый скан лабораторного домена ≤ 5 мин без настроек, в том числе на «ужесточённом» контроллере.
4	Веб-мастер и экспресс-путь обязательно	9–13	Локальный веб-интерфейс: кнопка «Сканировать», семь шагов мастера подключения, живой ход выполнения, отчёт в браузере; --demo на синтетическом снимке; обезличивание отчёта; состояния «проверено / пройдено / пропущено».	K4: три действия и ≤ 5 мин до отчёта — измеряется в CI на каждом выпуске.
5	Пакет для согласования, упаковка до выпуска	12–14	Пакет для проверки безопасности генерируется CI: модель угроз, схема сетевых взаимодействий, манифест запросов, SBOM, результаты сканеров, инструкция для SOC, доказательство «только чтение». MSI, .deb, .rpm; скрипт учётной записи аудита с -WhatIf; --dry-run, --manifest, журнал запуска; заявки в белые списки антивирусов.	K5: выпуск блокируется, если в пакете не хватает хотя бы одного артефакта.
6	Закрытая альфа обязательно	14–16	5–10 пилотных доменов (знакомые администраторы, MSP, лаборатории); проверка на Samba AD DC, РЕД АДМ, Альт Домен; разбор ложных срабатываний по обезличенным снимкам; подключён второй сопровождающий.	K6: ноль инцидентов на боевых доменах, ≥ 3 развёрнутых отзыва, ложные срабатывания закрыты.
7	Публичный выпуск 0.1 обязательно	16–18	GitHub Releases и зеркало в РФ, winget и Homebrew, образец отчёта онлайн, README с ответом «почему бесплатно», статья на Хабре и англоязычная публикация.	K7: подписанные сборки на трёх ОС, пакет для согласования опубликован.
8	После выпуска по ситуации	18+	Сравнение запусков и расписание; fix --plan; проверки от сообщества; FreeIPA / ALD Pro (v2); Entra ID (v3); подпись для Astra Linux; независимый аудит кода; при спросе — коммерческая поддержка.	Отдельная контрольная точка на каждый пункт.

КРИТИЧЕСКИЙ ПУТЬ



Параллельно с первого дня: заказ сертификата, лаборатория Samba в CI, пакет для согласования как часть конвейера, а не задача в конце.

Три запрета: публичный коммит до письма работодателя; код проверок до каталога; публичный выпуск без подписи и пакета для согласования.

ДЕВЯТЬ ОБЯЗАТЕЛЬНЫХ ШАГОВ

- Согласие работодателя о границе ИС
- Чистое название (проверки собственности)
- Сертификат с немедленной репутацией
- Каталог проверок раньше кода (чистая комната)
- Конвейер: воспроизводимая сборка, подпись, SBOM
- Движок AD с архитектурой снимков и doctor
- Веб-мастер, экспресс-путь ≤ 5 мин
- Пакет для согласования из CI
- Закрытая альфа на чужих доменах

ГЛАВНЫЕ РИСКИ ПЛАНА

- Письмо затягивается → работать в приватном репозитории; этапы 1–4 не блокируются.
- Сертификат не успевает → альфа раздаётся по рукам с проверкой хеша; выпуск ждёт.
- Один человек, мало часов → второй сопровождающий к K2; каталог и проверки можно делегировать, движок — нет.
- Рост требований → критерии готовности зафиксированы; всё новое — в этап 8.
- SOC пилота блокирует запуск → инструкция для SOC и --dry-run готовы к альфе.